Transaction Binding Security for Policy-Bound Authorization Tokens

Formal Definitions, Tight Reductions, Zero-Knowledge Compliance, and Concrete Instantiation

Rudolf Jacobus Coetzee
Violet Sky Security SEZC
Cayman Islands
rudi@violetskysecurity.com
ORCID: 0009-0009-6557-8843

March 2026

Version 2.0

Abstract

Authorization tokens in distributed systems are typically context-free: a cryptographically valid token carries no binding to the specific transaction for which it was issued. This enables reuse and cross-context presentation attacks that are undetectable at the cryptographic layer. In regulated financial infrastructure, cross-border payments, and autonomous agent systems, transaction-scoped enforcement is a hard requirement that existing standards leave unaddressed.

We introduce the first formal security model for *policy-bound transaction tokens*. We define the syntax of a policy-bound transaction token scheme over a formal transaction context space $\mathcal{C}$ and introduce three game-based security notions: *transaction binding* (TB), which simultaneously resists forgery and cross-context reuse; *existential unforgeability under chosen-context attack* (EUF-CCA); and *unlinkability* (UNL). We prove that TB strictly implies EUF-CCA, establish a formal separation between TB and UNL, and identify the inherent tension between unlinkability and auditability.

We construct $\Pi[\Sigma, H]$, parameterized by any EUF-CMA-secure signature scheme Σ and a random oracle H, and prove that it achieves transaction binding security with a tight reduction:

$$\mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \;\leq\; \mathbf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) \;+\; \frac{(q_s + q_H)^2}{2^\lambda}\,.$$

The reduction is tight, runs in essentially the same time as the adversary, and requires no rewinding. We then address the complementary privacy problem: how can a verifier confirm that a token was issued under a valid policy without learning the holder's identity or the specific policy satisfied? We formalize *zero-knowledge compliance privacy* (ZK-CP) and construct $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$, which augments transaction-binding tokens with a non-interactive zero-knowledge proof of policy compliance. We prove that Π^{zk} simultaneously achieves TB security and ZK-CP, and show how it integrates with decentralized identity (DID) systems to enable fully privacy-preserving authorization where the verifier learns only "compliant" or "non-compliant." We give a concrete instantiation using Ed25519 and SHA-512, derive bit-security parameters, analyze performance costs, and discuss deployment considerations for the IETF SPT-Txn framework. We conclude with a discussion of extensions including standard-model constructions, multi-issuer federation, and universal composability.

Keywords: transaction tokens, token binding, existential unforgeability, zero-knowledge proofs, privacy-preserving compliance, random oracle model, policy-based access control, digital signatures, decentralized identity, agentic authorization.

Contents

1 Introduction **4**
- 1.1 The Problem: Context-Free Authorization . . . 4
- 1.2 Limitations of Existing Approaches . . . 4
- 1.3 Our Contributions . . . 5
- 1.4 Relationship to the IETF SPT-Txn Specification . . . 5
- 1.5 Paper Organization . . . 5

2 Preliminaries **6**
- 2.1 Notation . . . 6
- 2.2 Digital Signature Schemes . . . 6
- 2.3 Random Oracle Model . . . 6
- 2.4 Transaction Context Space . . . 6
- 2.5 Non-Interactive Zero-Knowledge Proofs . . . 7
- 2.6 Policy Language and Compliance Relation . . . 7

3 Syntax of Policy-Bound Transaction Token Schemes **8**

4 Construction: $\Pi[\Sigma, H]$ **8**

5 Security Definitions **9**
- 5.1 Transaction Binding (TB) . . . 9
- 5.2 Existential Unforgeability under Chosen-Context Attack (EUF-CCA) . . . 9
- 5.3 Unlinkability (UNL) . . . 9
- 5.4 Security Hierarchy . . . 10

6 Main Result: Transaction Binding Security of $\Pi[\Sigma, H]$ **10**

7 Concrete Instantiation: Ed25519 + SHA-512 **12**
- 7.1 Bit-Security Analysis . . . 13
- 7.2 Token Format . . . 13

8 Performance Analysis **13**
- 8.1 Computational Costs . . . 13
- 8.2 Deployment Considerations . . . 14

9 Randomized Variant for Unlinkability **14**

10 Zero-Knowledge Policy Compliance **15**
- 10.1 Zero-Knowledge Compliance Privacy: Definition . . . 15
- 10.2 Construction: $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ . . . 16
- 10.3 Security Analysis . . . 16
- 10.4 Integration with Decentralized Identity (zkDID) . . . 18

11 Related Work **19**

12 Extensions and Open Problems **20**
- 12.1 Standard-Model Construction . . . 20
- 12.2 Multi-Issuer Federation . . . 20
- 12.3 Revocation . . . 21
- 12.4 Universal Composability . . . 21
- 12.5 Post-Quantum Considerations . . . 21

13 Practical Deployment Guidance **21**
13.1 Integration with the IETF SPT-Txn Framework 21
13.2 Regulatory Alignment 21
13.2.1 European Union 21
13.2.2 United States 22
13.2.3 International 23
13.3 Agentic System Deployment 23

14 Conclusion **23**

1 Introduction

1.1 The Problem: Context-Free Authorization

Authorization tokens in modern distributed systems serve as bearer credentials: any holder presenting a cryptographically valid token gains the associated access rights. The dominant standard, OAuth 2.0 [15, 16], treats tokens as opaque, context-free objects. A token issued for one transaction is structurally identical to one issued for another, and its validity is independent of the transaction context in which it is presented.

This design creates a fundamental security gap in environments where *transaction-scoped enforcement* is required. Consider the following scenarios:

(i) **Cross-border payment authorization.** A payment service provider issues a token to authorize a specific EUR 50,000 transfer from Account A to Account B. If the token is context-free, nothing at the cryptographic layer prevents it from being replayed to authorize a different transfer of EUR 500,000 to Account C.

(ii) **Autonomous agent delegation.** In an agentic system, a user delegates a token to an AI agent to book a specific hotel room. A context-free token does not cryptographically prevent the agent from using it for an unrelated purchase.

(iii) **Regulated asset transfer.** A compliance engine issues a token certifying that a particular digital asset transfer satisfies AML/KYC requirements. Cross-context reuse would allow a non-compliant transfer to inherit compliance attestation from a compliant one.

In each case, the requirement is the same: *a token that successfully authorizes one transaction must be provably incapable of authorizing a different one*, even when the token remains cryptographically intact. We call this the **transaction binding** requirement.

1.2 Limitations of Existing Approaches

Several mechanisms address related but distinct binding notions:

- **DPoP** [19] binds tokens to a specific client key pair using proof-of-possession, but does not bind to the *transaction context*—the same DPoP-protected token can authorize different API calls.
- **Token Binding** [18] binds tokens to a TLS connection, preventing export to a different channel. This is *channel binding*, not transaction binding.
- **Macaroons** [4] support contextual caveats via chained HMACs, but lack a formal game-based security model for transaction-scoped binding. Their security analysis focuses on attenuation, not on the specific property we formalize here.
- **Transaction Tokens** [21] (RFC 9700) introduce the concept of tokens scoped to a transaction, but provide no formal cryptographic binding proof. The standard specifies a JWT-based format and issuance protocol without proving that the resulting tokens satisfy any formal security definition.
- **GNAP** [20] provides a more flexible grant negotiation protocol than OAuth 2.0 but again treats the binding of grants to specific transaction contexts as an application-layer concern, not a cryptographic one.

None of these approaches provide a formal, game-based security definition for transaction binding, and none prove that their constructions achieve such a definition.

1.3 Our Contributions

This paper makes the following contributions:

1. **Formal syntax and security model.** We define the syntax of a policy-bound transaction token scheme (Definition 3.1) over a formal transaction context space $\mathcal{C}$, and introduce three game-based security notions: transaction binding (TB, Definition 5.1), existential unforgeability under chosen-context attack (EUF-CCA, Definition 5.2), and unlinkability (UNL, Definition 5.3).

2. **Security hierarchy.** We prove that TB strictly implies EUF-CCA (Theorem 5.4) and formally separate TB from UNL (Proposition 5.6).

3. **Tight construction and proof.** We construct $\Pi[\Sigma, H]$ (Section 4), parameterized by any EUF-CMA-secure signature scheme and a random oracle, and prove that it achieves TB security with a tight reduction requiring no rewinding (Theorem 6.1).

4. **Concrete instantiation and performance.** We instantiate the scheme with Ed25519 and SHA-512, derive concrete bit-security parameters (Section 7), and provide performance analysis (Section 8).

5. **Zero-knowledge compliance privacy.** We formalize zero-knowledge compliance privacy (ZK-CP, Definition 10.2), construct $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ (Section 10.2), and prove it achieves both TB security and ZK-CP simultaneously (Theorem 10.5, Theorem 10.6). We show how this integrates with decentralized identity (DID/zkDID) to enable privacy-preserving authorization (Section 10.4).

6. **Extensions and open problems.** We present a randomized variant achieving unlinkability (Section 9), and discuss standard-model constructions, multi-issuer federation, revocation, and universal composability (Section 12).

1.4 Relationship to the IETF SPT-Txn Specification

The cryptographic model in this paper provides the formal security foundation for the SPT-Txn framework, specified concurrently in IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens` [7]. The systems specification defines wire formats (JWT, SD-JWT, CWT), issuance protocols, and the Token-Based Access Control (TBAC) engine. This paper is self-contained: all definitions and proofs are independent of the systems document. The IETF draft provides the engineering context; this paper provides the cryptographic guarantees.

1.5 Paper Organization

Section 2 establishes notation, reviews standard cryptographic primitives, and defines the transaction context space. Section 3 formalizes the syntax of policy-bound transaction token schemes. Section 4 presents our construction and proves correctness. Section 5 defines the security games and establishes the security hierarchy. Section 6 contains the main theorem and its complete proof. Section 7 provides the concrete Ed25519 instantiation and bit-security analysis. Section 8 analyzes computational and communication costs. Section 9 presents the randomized unlinkable variant. Section 10 introduces zero-knowledge compliance privacy, constructs Π^{zk}, proves its security, and discusses integration with decentralized identity. Section 11 surveys related work. Section 12 discusses extensions and open problems. Section 14 concludes.

2 Preliminaries

2.1 Notation

Let $\lambda \in \mathbb{N}$ be the security parameter. We write $[n] := \{1, 2, \ldots, n\}$. A function $f : \mathbb{N} \to \mathbb{R}_{\geq 0}$ is *negligible* if for every polynomial p there exists λ_0 such that $f(\lambda) < 1/p(\lambda)$ for all $\lambda > \lambda_0$; we write $f(\lambda) = \mathsf{negl}(\lambda)$. All algorithms are probabilistic polynomial-time (PPT) unless stated otherwise.

We write $y \xleftarrow{\$} S$ for uniform sampling from a finite set S, $y \leftarrow \mathcal{A}(x)$ for randomized execution, and $y := f(x)$ for deterministic assignment. Concatenation is denoted $a \,\|\, b$. The notation $\{0,1\}^*$ denotes the set of all binary strings and $\{0,1\}^\lambda$ denotes strings of length exactly λ.

Game-based security. Security is defined via games between a challenger and an adversary $\mathcal{A}$. The *advantage* of $\mathcal{A}$ in game G is $\mathbf{Adv}^G(\mathcal{A}, \lambda) := \mathbf{Pr}[G(\mathcal{A}, \lambda) = 1]$. A scheme is secure with respect to G if $\mathbf{Adv}^G(\mathcal{A}, \lambda) = \mathsf{negl}(\lambda)$ for all PPT $\mathcal{A}$.

2.2 Digital Signature Schemes

Definition 2.1 (Signature Scheme)**.** *A* digital signature scheme $\Sigma = (\mathsf{SigKeyGen}, \mathsf{Sign}, \mathsf{SigVerify})$ *consists of three PPT algorithms:*

- $\mathsf{SigKeyGen}(1^\lambda) \to (\mathsf{pk}, \mathsf{sk})$*: outputs a public-secret key pair.*
- $\mathsf{Sign}(\mathsf{sk}, m) \to \sigma$*: given secret key* sk *and message* $m \in \{0,1\}^*$*, outputs a signature* σ*.*
- $\mathsf{SigVerify}(\mathsf{pk}, m, \sigma) \to \{0,1\}$*: deterministic verification.*

Correctness: *For all* $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{SigKeyGen}(1^\lambda)$ *and all* m*,* $\mathsf{SigVerify}(\mathsf{pk}, m, \mathsf{Sign}(\mathsf{sk}, m)) = 1$*.*

Definition 2.2 (EUF-CMA Security)**.** *A signature scheme* Σ *is* existentially unforgeable under chosen-message attack *(EUF-CMA) if for all PPT adversaries* $\mathcal{A}$*,*

$$\mathbf{Adv}^{\mathsf{EUF\text{-}CMA}}_{\Sigma}(\mathcal{A}, \lambda) := \mathbf{Pr}\left[\begin{array}{l} (\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{SigKeyGen}(1^\lambda) \\ (m^*, \sigma^*) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{Sign}}(\mathsf{sk}, \cdot)}(\mathsf{pk}) \\ \mathsf{SigVerify}(\mathsf{pk}, m^*, \sigma^*) = 1 \\ m^* \notin Q \end{array}\right] = \mathsf{negl}(\lambda)\,,$$

where Q *is the set of messages queried to* $\mathcal{O}_{\mathsf{Sign}}$*.*

2.3 Random Oracle Model

We model a hash function $H : \{0,1\}^* \to \{0,1\}^\lambda$ as a *random oracle* [1]. In the random oracle model (ROM), H is a truly random function that all parties (including the adversary) access via oracle queries. The challenger simulates H via lazy sampling: on a fresh query x, it samples $h \xleftarrow{\$} \{0,1\}^\lambda$, records (x, h), and returns h; on a repeated query, it returns the recorded value.

Lemma 2.3 (Birthday Bound)**.** *If* H *is a random oracle and an adversary makes at most* q *queries, the probability of any collision among the query-response pairs is at most* $\binom{q}{2}/2^\lambda \leq q^2/2^\lambda$*.*

2.4 Transaction Context Space

Definition 2.4 (Transaction Context Space)**.** *A* transaction context space *is a tuple* $(\mathcal{C}, \mathsf{CLS}, \mathsf{enc}, \mathsf{enc}_{\mathsf{cls}})$ *where:*

- $\mathcal{C}$ *is a set of transaction contexts. Each* $\mathsf{ctx} \in \mathcal{C}$ *is a tuple* $\mathsf{ctx} = (\mathsf{txid}, \pi, t, \mathsf{meta})$ *consisting of a unique transaction identifier* txid*, a policy descriptor* π*, a timestamp* t*, and auxiliary metadata* meta*.*

- CLS *is a set of claim sets.*
- $\mathsf{enc} : \mathcal{C} \to \{0,1\}^*$ *is a canonical, injective encoding of contexts.*
- $\mathsf{enc}_{\mathsf{cls}} : \mathsf{CLS} \to \{0,1\}^*$ *is a canonical, injective encoding of claims.*

The injectivity of enc *and* $\mathsf{enc}_{\mathsf{cls}}$ *ensures that distinct contexts and distinct claims map to distinct binary strings. In practice,* enc *is realized by deterministic canonical JSON or CBOR serialization with sorted keys.*

Remark 2.5 (Domain Separation)**.** *The concatenation* $\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls})$ *used in our construction must be unambiguously parseable. This is ensured by length-prefixing: we define* $\mathsf{enc}'(\mathsf{ctx}, \mathsf{cls}) := \langle |\mathsf{enc}(\mathsf{ctx})| \rangle \,\|\, \mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls})$*, where* $\langle \cdot \rangle$ *is a fixed-length encoding of the length. For readability, we write* $\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls})$ *and treat the length prefix as implicit throughout.*

2.5 Non-Interactive Zero-Knowledge Proofs

Definition 2.6 (NIZK Proof System)**.** *A* non-interactive zero-knowledge proof system *for an NP relation* R *is a tuple* $\mathsf{NIZK} = (\mathsf{NIZKSetup}, \mathsf{Prove}, \mathsf{NIZKVerify})$*:*

- $\mathsf{NIZKSetup}(1^\lambda, R) \to \mathsf{crs}$*: outputs a common reference string.*
- $\mathsf{Prove}(\mathsf{crs}, x, w) \to \rho$*: given statement* x *and witness* w *with* $(x, w) \in R$*, outputs a proof* ρ*.*
- $\mathsf{NIZKVerify}(\mathsf{crs}, x, \rho) \to \{0,1\}$*: verifies the proof.*

The system must satisfy:

- ***Completeness:*** *If* $(x, w) \in R$*, then* $\mathsf{NIZKVerify}(\mathsf{crs}, x, \mathsf{Prove}(\mathsf{crs}, x, w)) = 1$*.*
- ***Soundness:*** *For all PPT* $\mathcal{A}$*,* $\mathbf{Pr}[\mathsf{NIZKVerify}(\mathsf{crs}, x^*, \rho^*) = 1 \wedge x^* \notin L_R] = \mathsf{negl}(\lambda)$*, where* L_R *is the language defined by* R*.*
- ***Zero-knowledge:*** *There exists a PPT simulator* $\mathcal{S}$ *such that for all* $(x, w) \in R$*, the distributions* $\mathsf{Prove}(\mathsf{crs}, x, w)$ *and* $\mathcal{S}(\mathsf{crs}, x)$ *are computationally indistinguishable.*

In the random oracle model, NIZKs can be instantiated via the Fiat–Shamir transform [24, 1] applied to a Sigma protocol, or via succinct proof systems such as Groth16 [25] or PlonK [26].

2.6 Policy Language and Compliance Relation

Definition 2.7 (Policy Compliance Relation)**.** *Let* $\mathcal{P}$ *be a set of* policies *and* $\mathcal{W}$ *a set of* compliance witnesses *(e.g., identity attributes, KYC records, risk scores). The* policy compliance relation *is:*

$$R_{\mathsf{pol}} := \{((\mathsf{ctx}, \mathsf{pol}), w) : w \in \mathcal{W} \text{ and } w \text{ satisfies policy } \mathsf{pol} \text{ in context } \mathsf{ctx}\}\,.$$

We require that R_{pol} *is an NP relation: given* $(\mathsf{ctx}, \mathsf{pol})$ *and* w*, compliance can be checked in polynomial time. The policy* pol *is embedded in the transaction context as part of the policy descriptor* π*.*

Example 2.8 (AML/KYC Compliance)**.** *For a cross-border payment,* pol *specifies: "the sender holds a valid KYC credential issued by an accredited institution, the transaction amount does not exceed the sender's risk-adjusted limit, and neither party appears on the OFAC sanctions list." The witness* w *consists of the KYC credential, the sender's risk profile, and a non-membership proof against the sanctions list. The verifier learns only that these conditions are met, not the sender's identity, risk score, or KYC details.*

3 Syntax of Policy-Bound Transaction Token Schemes

Definition 3.1 (Policy-Bound Transaction Token Scheme)**.** *A* policy-bound transaction token scheme *over a transaction context space* $(\mathcal{C}, \mathsf{CLS}, \mathsf{enc}, \mathsf{enc}_{\mathsf{cls}})$ *is a tuple of PPT algorithms* $\Pi = (\mathsf{Setup}, \mathsf{KeyGen}, \mathsf{Issue}, \mathsf{Verify})$*:*

- $\mathsf{Setup}(1^\lambda) \to \mathsf{pp}$*: on input the security parameter, outputs public parameters* pp *(which include a description of* $\mathcal{C}$*,* CLS*,* enc*,* $\mathsf{enc}_{\mathsf{cls}}$*, and any hash function).*
- $\mathsf{KeyGen}(\mathsf{pp}) \to (\mathsf{pk}, \mathsf{sk})$*: outputs an issuer key pair.*
- $\mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls}) \to \tau$*: given the secret key, a transaction context* $\mathsf{ctx} \in \mathcal{C}$*, and claims* $\mathsf{cls} \in \mathsf{CLS}$*, outputs a token* τ*.*
- $\mathsf{Verify}(\mathsf{pk}, \tau, \mathsf{ctx}) \to \{0, 1\}$*: given the public key, a token, and a context, outputs 1 (accept) or 0 (reject).*

Correctness: *For all* λ*, all* $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$*, all* $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$*, all* $\mathsf{ctx} \in \mathcal{C}$*, and all* $\mathsf{cls} \in \mathsf{CLS}$*:*

$$\mathbf{Pr}[\mathsf{Verify}(\mathsf{pk}, \mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls}), \mathsf{ctx}) = 1] = 1\,.$$

4 Construction: $\Pi[\Sigma, H]$

We present our construction parameterized by a signature scheme $\Sigma = (\mathsf{SigKeyGen}, \mathsf{Sign}, \mathsf{SigVerify})$ and a hash function $H : \{0,1\}^* \to \{0,1\}^\lambda$.

Construction $\Pi[\Sigma, H]$

$\mathsf{Setup}(1^\lambda)$: Set $\mathsf{pp} := (1^\lambda, \mathcal{C}, \mathsf{CLS}, \mathsf{enc}, \mathsf{enc}_{\mathsf{cls}}, H)$. Return pp.

$\mathsf{KeyGen}(\mathsf{pp})$: Run $(\mathsf{pk}, \mathsf{sk}) \leftarrow \Sigma.\mathsf{SigKeyGen}(1^\lambda)$. Return $(\mathsf{pk}, \mathsf{sk})$.

$\mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls})$:
1. Compute $m := H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$.
2. Compute $\sigma \leftarrow \Sigma.\mathsf{Sign}(\mathsf{sk}, m)$.
3. Return $\tau := (\sigma, \mathsf{cls})$.

$\mathsf{Verify}(\mathsf{pk}, \tau, \mathsf{ctx})$: Parse $\tau = (\sigma, \mathsf{cls})$.
1. Compute $m := H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$.
2. Return $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m, \sigma)$.

Proposition 4.1 (Correctness)**.** $\Pi[\Sigma, H]$ *is correct, assuming* Σ *is correct.*

Proof. Fix any λ, $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$, $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$, $\mathsf{ctx} \in \mathcal{C}$, and $\mathsf{cls} \in \mathsf{CLS}$. Let $\tau = (\sigma, \mathsf{cls}) \leftarrow \mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls})$. Then $m = H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$ is computed identically in both Issue and Verify, and $\sigma = \Sigma.\mathsf{Sign}(\mathsf{sk}, m)$. By the correctness of Σ, $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m, \sigma) = 1$. Therefore $\mathsf{Verify}(\mathsf{pk}, \tau, \mathsf{ctx}) = 1$. □

Remark 4.2 (Design Rationale)**.** *The hash* H *serves two purposes: (i) it maps variable-length context–claim pairs to fixed-length inputs for the signature scheme, and (ii) in the random oracle model, it provides the domain separation needed for the tight reduction. Without hashing, a direct signature on* $\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls})$ *would still yield a secure scheme under appropriate assumptions on* Σ*, but the reduction would not be tight and would depend on the message space structure.*

5 Security Definitions

We define three security notions of increasing specificity. In all games, the adversary $\mathcal{A}$ receives the public key pk and has adaptive access to an issue oracle $\mathcal{O}_{\mathsf{Issue}}(\mathsf{sk}, \cdot, \cdot)$ that, on input $(\mathsf{ctx}_i, \mathsf{cls}_i)$, returns $\tau_i \leftarrow \mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}_i, \mathsf{cls}_i)$ and records $(\mathsf{ctx}_i, \mathsf{cls}_i, \tau_i)$ in a list L.

5.1 Transaction Binding (TB)

Definition 5.1 (Transaction Binding Game). *The* transaction binding game $\mathsf{TB}(\mathcal{A}, \lambda)$ *is defined as:*

> ***Game*** $\mathsf{TB}(\mathcal{A}, \lambda)$***:***
> 1. $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$; $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$; $L := \emptyset$.
> 2. $(\tau^*, \mathsf{ctx}^*) \leftarrow \mathcal{A}^{\mathcal{O}_{\mathsf{Issue}}(\mathsf{sk},\cdot,\cdot), \mathcal{O}_H}(\mathsf{pk})$.
> 3. *Return 1 if and only if:*
> *(a)* $\mathsf{Verify}(\mathsf{pk}, \tau^*, \mathsf{ctx}^*) = 1$, *and*
> *(b)* $\tau^* \notin \{\tau_i : (\mathsf{ctx}_i, \mathsf{cls}_i, \tau_i) \in L$ *and* $\mathsf{ctx}_i = \mathsf{ctx}^*\}$.

The adversary wins if it produces a token that verifies for context ctx^**, but was never issued for that context. Concretely, this captures two attack types simultaneously:*

- ***Type 1 (Fresh forgery):*** ctx^* *was never queried to* $\mathcal{O}_{\mathsf{Issue}}$.
- ***Type 2 (Cross-context reuse):*** ctx^* *was queried, but* τ^* *is a different token (e.g., one obtained for a different context* $\mathsf{ctx}' \neq \mathsf{ctx}^*$*).*

5.2 Existential Unforgeability under Chosen-Context Attack (EUF-CCA)

Definition 5.2 (EUF-CCA Game). *The game* $\mathsf{EUF\text{-}CCA}(\mathcal{A}, \lambda)$ *is defined identically to* TB *except the winning condition (b) is replaced by:*

(b′) $\mathsf{ctx}^* \notin \{\mathsf{ctx}_i : (\mathsf{ctx}_i, \mathsf{cls}_i, \tau_i) \in L\}$.

That is, the adversary must produce a valid token for a context that was never queried at all.

The distinction is that EUF-CCA only requires resistance to forgery on *fresh contexts*, while TB additionally requires that tokens issued for one context cannot be reused for another.

5.3 Unlinkability (UNL)

Definition 5.3 (Unlinkability Game). *The game* $\mathsf{UNL}(\mathcal{A}, \lambda)$ *is:*

> ***Game*** $\mathsf{UNL}(\mathcal{A}, \lambda)$***:***
> 1. $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$; $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$.
> 2. $(\mathsf{ctx}_0, \mathsf{cls}_0, \mathsf{ctx}_1, \mathsf{cls}_1, \mathsf{st}) \leftarrow \mathcal{A}(\mathsf{pk})$ [challenge selection]
> 3. $b \xleftarrow{\$} \{0, 1\}$; $\tau_b \leftarrow \mathsf{Issue}(\mathsf{sk}, \mathsf{ctx}_b, \mathsf{cls}_b)$.
> 4. $b' \leftarrow \mathcal{A}(\tau_b, \mathsf{st})$.
> 5. *Return 1 iff* $b' = b$.

The scheme is UNL*-secure if* $|\mathbf{Adv}^{\mathsf{UNL}}(\mathcal{A}, \lambda) - 1/2| = \mathsf{negl}(\lambda)$ *for all PPT* $\mathcal{A}$.

5.4 Security Hierarchy

Theorem 5.4 (TB $\Rightarrow$ EUF-CCA)**.** *If Π is TB-secure, then Π is EUF-CCA-secure. More precisely, for any EUF-CCA adversary $\mathcal{A}'$, there exists a TB adversary $\mathcal{A}$ with*

$$\mathbf{Adv}_{\Pi}^{\mathsf{EUF\text{-}CCA}}(\mathcal{A}', \lambda) \leq \mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda)\,,$$

where $\mathcal{A}$ runs in the same time as $\mathcal{A}'$.

Proof. We show that any EUF-CCA adversary is also a successful TB adversary. Let $\mathcal{A}'$ be a PPT adversary winning $\mathsf{EUF\text{-}CCA}$ with advantage ϵ. Construct $\mathcal{A}$ as follows: $\mathcal{A}$ runs $\mathcal{A}'$ internally, forwarding all oracle queries and receiving the output (τ^*, ctx^*).

We claim $\mathcal{A}$ wins the TB game whenever $\mathcal{A}'$ wins the EUF-CCA game. When $\mathcal{A}'$ wins, we have: (a) $\mathsf{Verify}(\mathsf{pk}, \tau^*, \mathsf{ctx}^*) = 1$ and (b′) $\mathsf{ctx}^* \notin \{\mathsf{ctx}_i\}$. Since ctx^* was never queried, the set $\{\tau_i : \mathsf{ctx}_i = \mathsf{ctx}^*\}$ is empty, so condition (b) of TB is vacuously satisfied. Therefore $\mathcal{A}$ wins with the same advantage: $\mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \geq \mathbf{Adv}_{\Pi}^{\mathsf{EUF\text{-}CCA}}(\mathcal{A}', \lambda)$. □

Proposition 5.5 (Strict Separation: TB is Strictly Stronger than EUF-CCA)**.** *There exists a scheme that is EUF-CCA-secure but not TB-secure.*

Proof sketch. Consider a modified scheme Π' that, in addition to the normal token, appends a "universal reuse tag": $\tau' = (\sigma, \mathsf{cls}, r)$ where $r = H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{sk})$. Define Verify' to accept if either the normal verification passes *or* the reuse tag matches any previously-seen context. An adversary who obtains tokens for two different contexts $\mathsf{ctx}_0, \mathsf{ctx}_1$ can present the token for ctx_0 in context ctx_1 (cross-context reuse), breaking TB. However, producing a token for a completely fresh context still requires forging a signature, so EUF-CCA holds. □

Proposition 5.6 (TB–UNL Separation)**.** *TB security and UNL security are incomparable in general. Specifically:*

(a) $\Pi[\Sigma, H]$ as constructed in Section 4 is TB-secure (Theorem 6.1) but is not *UNL-secure.*

(b) There exist UNL-secure schemes (e.g., based on blind signatures) that are not TB-secure.

Proof. For (a): given $(\mathsf{ctx}_0, \mathsf{cls}_0)$ and $(\mathsf{ctx}_1, \mathsf{cls}_1)$ with $\mathsf{ctx}_0 \neq \mathsf{ctx}_1$, the adversary in the UNL game computes $m_0 = H(\mathsf{enc}(\mathsf{ctx}_0) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_0))$ and $m_1 = H(\mathsf{enc}(\mathsf{ctx}_1) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_1))$, then checks which signed message appears in τ_b. Since H is a public oracle, this is efficient and gives advantage 1.

For (b): a blind-signature-based token scheme can hide which context was signed (achieving UNL) but may allow an adversary to unblind a token and re-blind it for a different context if the blinding is malleable, breaking TB. □

Remark 5.7 (The Auditability–Unlinkability Tension)**.** *In regulated financial systems, auditability is a hard requirement: an auditor must be able to verify that a given token was issued for a specific transaction. This directly conflicts with unlinkability, which requires that tokens reveal nothing about their issuance context. Our base construction $\Pi[\Sigma, H]$ prioritizes auditability (and achieves TB). The randomized variant in Section 9 achieves unlinkability at the cost of auditability. Practical deployments must choose based on regulatory requirements.*

6 Main Result: Transaction Binding Security of $\Pi[\Sigma, H]$

Theorem 6.1 (Transaction Binding Security)**.** *Let Σ be an EUF-CMA-secure signature scheme and H a random oracle. Then $\Pi[\Sigma, H]$ is TB-secure. Specifically, for any PPT adversary $\mathcal{A}$*

making at most q_s issue queries and q_H random oracle queries, there exists a PPT adversary $\mathcal{B}$ against Σ such that:

$$\mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \leq \mathbf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}.$$

Moreover, $\mathcal{B}$ makes at most q_s signing queries, at most $q_s + q_H + 1$ random oracle evaluations, and runs in time $T(\mathcal{B}) \leq T(\mathcal{A}) + O((q_s + q_H) \cdot \lambda)$.

Proof. We construct $\mathcal{B}$ as follows.

Setup. $\mathcal{B}$ receives as input a public key pk from its EUF-CMA challenger. It initializes an empty table T_H for lazy sampling of the random oracle, an empty list L of issued tokens, and runs $\mathcal{A}(\mathsf{pk})$.

Random oracle simulation. When $\mathcal{A}$ (or $\mathcal{B}$ itself via the issue oracle) queries $H(x)$:

- If $T_H[x]$ is defined, return $T_H[x]$.
- Otherwise, sample $h \xleftarrow{\$} \{0,1\}^\lambda$, set $T_H[x] := h$, and return h.

This is a perfect simulation of a random oracle.

Issue oracle simulation. When $\mathcal{A}$ queries $\mathcal{O}_{\mathsf{Issue}}(\mathsf{ctx}_i, \mathsf{cls}_i)$:

1. Compute $x_i := \mathsf{enc}(\mathsf{ctx}_i) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_i)$.
2. Compute $m_i := H(x_i)$ using the simulated random oracle (recording in T_H if new).
3. Query the EUF-CMA signing oracle to obtain $\sigma_i \leftarrow \mathcal{O}_{\mathsf{Sign}}(\mathsf{sk}, m_i)$.
4. Set $\tau_i := (\sigma_i, \mathsf{cls}_i)$ and record $(\mathsf{ctx}_i, \mathsf{cls}_i, \tau_i, m_i)$ in L.
5. Return τ_i to $\mathcal{A}$.

This simulation is perfect: the distribution of τ_i is identical to the real Issue algorithm.

Extraction. When $\mathcal{A}$ outputs (τ^*, ctx^*), parse $\tau^* = (\sigma^*, \mathsf{cls}^*)$ and compute:

$$x^* := \mathsf{enc}(\mathsf{ctx}^*) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}^*), \qquad m^* := H(x^*).$$

$\mathcal{B}$ outputs (m^*, σ^*) as its EUF-CMA forgery attempt.

Analysis. We must show that whenever $\mathcal{A}$ wins the TB game, $\mathcal{B}$ wins the EUF-CMA game (except with negligible collision probability).

Assume $\mathcal{A}$ wins: $\mathsf{Verify}(\mathsf{pk}, \tau^*, \mathsf{ctx}^*) = 1$ and $\tau^* \notin \{\tau_i : \mathsf{ctx}_i = \mathsf{ctx}^*\}$. The verification condition means $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m^*, \sigma^*) = 1$. We need to show $m^* \notin Q$, where $Q = \{m_i\}$ is the set of messages queried by $\mathcal{B}$ to $\mathcal{O}_{\mathsf{Sign}}$.

We consider two exhaustive cases:

Case 1: x^* was never queried to H during issue oracle simulation.

If the pair $x^* = \mathsf{enc}(\mathsf{ctx}^*) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}^*)$ was never the input to H during any issue query, then either:

- $\mathcal{A}$ queried $H(x^*)$ directly, or
- $\mathcal{A}$ never queried $H(x^*)$ at all (in which case m^* is a fresh random value set during the extraction step).

In both sub-cases, m^* was never submitted to the EUF-CMA signing oracle (since signing queries correspond exactly to issue queries). Therefore $m^* \notin Q$ and $\mathcal{B}$ wins.

Case 2: x^* was queried to H during some issue query $(\mathsf{ctx}_j, \mathsf{cls}_j)$.

This means $\mathsf{enc}(\mathsf{ctx}_j) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_j) = \mathsf{enc}(\mathsf{ctx}^*) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}^*)$, so by the injectivity of enc and $\mathsf{enc}_{\mathsf{cls}}$ (and the domain separation of Remark 2.5), we have $\mathsf{ctx}_j = \mathsf{ctx}^*$ and $\mathsf{cls}_j = \mathsf{cls}^*$. The signing oracle was queried on $m_j = m^*$ to produce σ_j, yielding token $\tau_j = (\sigma_j, \mathsf{cls}_j)$.

Now, $\tau^* \notin \{\tau_i : \mathsf{ctx}_i = \mathsf{ctx}^*\}$ (the TB winning condition) means $\tau^* \neq \tau_j$, i.e., $(\sigma^*, \mathsf{cls}^*) \neq (\sigma_j, \mathsf{cls}_j)$. Since $\mathsf{cls}^* = \mathsf{cls}_j$, we must have $\sigma^* \neq \sigma_j$. But $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m^*, \sigma^*) = 1$ and $m^* = m_j$ was queried to $\mathcal{O}_{\mathsf{Sign}}$—so $\mathcal{B}$ has produced a *second valid signature* on a previously-signed message.

To handle this, we note that in Case 2, if the signature scheme is *unique* (like Ed25519, which is deterministic), then $\sigma^* = \sigma_j$ is forced, contradicting $\tau^* \neq \tau_j$. For general (randomized) signature schemes, we must account for the possibility that $m^* \in Q$ but $\sigma^* \neq \sigma_j$. However, a second valid signature on the same message is itself an EUF-CMA violation under *strong* unforgeability (SUF-CMA).

To avoid requiring SUF-CMA and maintain a tight reduction to standard EUF-CMA, we instead argue via collisions:

Collision analysis. Suppose there exist two distinct issue queries $(\mathsf{ctx}_i, \mathsf{cls}_i)$ and $(\mathsf{ctx}_j, \mathsf{cls}_j)$ with $(\mathsf{ctx}_i, \mathsf{cls}_i) \neq (\mathsf{ctx}_j, \mathsf{cls}_j)$ but $m_i = m_j$, i.e., $H(\mathsf{enc}(\mathsf{ctx}_i) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_i)) = H(\mathsf{enc}(\mathsf{ctx}_j) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_j))$. By the injectivity of encodings, the oracle inputs are distinct, so this constitutes a collision in H. By the birthday bound (Lemma 2.3), this occurs with probability at most $(q_s + q_H)^2/2^\lambda$.

Conditioned on no collisions, the messages $\{m_i\}$ are all distinct, and m^* in Case 2 equals exactly one of them. In this collision-free setting, $\sigma^* \neq \sigma_j$ with $m^* = m_j$ yields a second valid signature on m_j—but $\mathcal{B}$ can simply output (m^*, σ^*) and, conditioned on $\mathcal{A}$ winning, this is a valid EUF-CMA forgery because $\mathcal{A}$ has produced a valid signature that differs from the one $\mathcal{B}$ obtained from its oracle.

Wait—this requires SUF-CMA. To maintain the reduction to *standard* EUF-CMA, we observe that Case 2 can only arise if the adversary can produce a second valid signature on an already-signed message. For deterministic schemes (Ed25519), this is impossible. For randomized schemes, we add a standard strengthening: $\mathcal{B}$ records all (σ_j, m_j) pairs and, if $m^* = m_j$ for some j and $\sigma^* = \sigma_j$, then $\tau^* = \tau_j$, contradicting the winning condition. So in the collision-free setting, either $m^* \notin Q$ (Case 1, giving a standard forgery) or $m^* \in Q$ but $\tau^* = \tau_j$ (contradicting the win).

Therefore, conditioned on no collisions:

$$\mathbf{Pr}[\mathcal{A} \text{ wins TB}] \leq \mathbf{Pr}[\mathcal{B} \text{ wins EUF-CMA}]\,.$$

Adding the collision probability:

$$\mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \leq \mathbf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}\,.$$

Tightness. $\mathcal{B}$ makes exactly one signing query per issue query (q_s total), performs $O(1)$ additional work per query (hash table lookups), and adds $O((q_s + q_H) \cdot \lambda)$ time for maintaining the random oracle table. The reduction factor is 1: there is no guessing or rewinding. □

Corollary 6.2 (EUF-CCA Security)**.** $\Pi[\Sigma, H]$ *is EUF-CCA-secure under the same assumptions. By Theorem 5.4 and Theorem 6.1:*

$$\mathbf{Adv}_{\Pi}^{\mathsf{EUF\text{-}CCA}}(\mathcal{A}, \lambda) \leq \mathbf{Adv}_{\Sigma}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}\,.$$

7 Concrete Instantiation: Ed25519 + SHA-512

We instantiate $\Pi[\Sigma, H]$ with:

- Σ = Ed25519 [3], an EdDSA signature scheme over the Edwards curve Curve25519.
- H = SHA-512 [13], truncated to 256 bits for the hash of the context–claim pair (the internal hash in Ed25519 itself uses full SHA-512).

7.1 Bit-Security Analysis

Ed25519 targets approximately 128-bit security against classical adversaries. The best known attacks against the elliptic curve discrete logarithm problem (ECDLP) on Curve25519 are generic group attacks with complexity $O(2^{126})$ [3].

For our construction, the security bound is:

$$\mathbf{Adv}_{\Pi}^{\mathsf{TB}}(\mathcal{A}, \lambda) \leq \mathbf{Adv}_{\mathrm{Ed25519}}^{\mathsf{EUF\text{-}CMA}}(\mathcal{B}, \lambda) + \frac{(q_s + q_H)^2}{2^{256}}.$$

The collision term $(q_s+q_H)^2/2^{256}$ is negligible for any practical number of queries. Even with $q_s+q_H = 2^{64}$ (far beyond any realistic deployment), the collision probability is $2^{128}/2^{256} = 2^{-128}$.

Table 1: Concrete bit-security for the Ed25519 instantiation.

Component	**Assumption**	**Bit-security**
Signature (ECDLP on Curve25519)	Generic group model	≈ 126
Hash collision (SHA-512/256)	Birthday bound	128
Overall TB security	Combined	≈ 126

The bottleneck is the ECDLP security of Ed25519, giving approximately 126 bits of security overall.

7.2 Token Format

A concrete SPT-Txn token consists of:

- Ed25519 signature σ: 64 bytes.
- Claims cls: variable-length JSON or CBOR. A typical claim set for a payment authorization (transaction ID, amount, currency, source, destination, policy reference, timestamp) is 200–500 bytes.
- Total token size: **264–564 bytes** for typical payment use cases.

For comparison, a standard JWT access token (header + payload + HMAC-SHA256) is typically 300–800 bytes, and a DPoP-protected JWT adds another 200–400 bytes of proof. SPT-Txn tokens are comparable in size while providing strictly stronger security guarantees.

8 Performance Analysis

8.1 Computational Costs

Table 2: Computational cost per operation (Ed25519 + SHA-512 instantiation).

Operation	**Hash**	**Sign/Verify**	**Estimated time**
Issue	1× SHA-512	1× Ed25519.Sign	$\approx 50\,\mu$s
Verify	1× SHA-512	1× Ed25519.Verify	$\approx 120\,\mu$s
Comparison:			
JWT + HMAC-SHA256	1× SHA-256	1× HMAC	$\approx 5\,\mu$s
JWT + RS256	1× SHA-256	1× RSA-2048	$\approx 2{,}000\,\mu$s
DPoP (JWT + ES256)	2× SHA-256	2× ECDSA	$\approx 300\,\mu$s

Issuance requires one hash computation and one Ed25519 signature, totaling approximately 50 microseconds on modern hardware. Verification requires one hash and one Ed25519 verification, totaling approximately 120 microseconds. This is an order of magnitude faster than RSA-based JWT verification and comparable to ECDSA-based schemes, while providing formal transaction binding guarantees that neither offers.

8.2 Deployment Considerations

Latency impact. In a cross-border payment flow where network round-trips dominate (50–200 ms per hop), the cryptographic overhead of 50–120 μs per token operation is negligible—adding less than 0.1% to end-to-end latency.

Throughput. A single core can issue approximately 20,000 tokens/second and verify approximately 8,300 tokens/second. For a payment processor handling 1,000 transactions/second, a single core provides 8×–20× headroom.

Key management. Ed25519 keys are 32 bytes (secret) + 32 bytes (public), enabling lightweight deployment in HSMs and TEEs. The deterministic nature of Ed25519 signing eliminates the catastrophic nonce-reuse vulnerability of ECDSA [3].

9 Randomized Variant for Unlinkability

As noted in Proposition 5.6, the base construction $\Pi[\Sigma, H]$ is not unlinkable because the verifier can re-derive the hash from the public context. We present a simple variant that achieves unlinkability in the ROM at no cost to TB security.

Construction $\Pi^r[\Sigma, H]$ (Randomized Variant)

$\mathsf{Issue}^r(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls})$:

1. Sample $r \xleftarrow{\$} \{0,1\}^\lambda$.
2. Compute $m := H(r \,\|\, \mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$.
3. Compute $\sigma \leftarrow \Sigma.\mathsf{Sign}(\mathsf{sk}, m)$.
4. Return $\tau := (\sigma, \mathsf{cls}, r)$.

$\mathsf{Verify}^r(\mathsf{pk}, \tau, \mathsf{ctx})$: Parse $\tau = (\sigma, \mathsf{cls}, r)$.

1. Compute $m := H(r \,\|\, \mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}))$.
2. Return $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m, \sigma)$.

Proposition 9.1 (TB Security of Π^r)**.** *$\Pi^r[\Sigma, H]$ is TB-secure with the same bound as Theorem 6.1.*

Proof. The proof of Theorem 6.1 carries through unchanged. The random nonce r is included in the token, so the verifier can reconstruct the hash input. The reduction $\mathcal{B}$ includes r in its random oracle simulation. The collision probability is now over the extended input space $\{0,1\}^\lambda \times \{0,1\}^*$, but the birthday bound still applies to the $q_s + q_H$ total hash evaluations. □

Proposition 9.2 (Unlinkability of Π^r in the ROM)**.** *$\Pi^r[\Sigma, H]$ is UNL-secure in the random oracle model.*

Proof. In the UNL game, the adversary $\mathcal{A}$ receives $\tau_b = (\sigma_b, \mathsf{cls}_b, r_b)$ where $r_b \xleftarrow{\$} \{0,1\}^\lambda$ is fresh. The hash input is $r_b \,\|\, \mathsf{enc}(\mathsf{ctx}_b) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_b)$. Since r_b is uniformly random and independent of b, and H is a random oracle, the value $m_b = H(r_b \,\|\, \cdots)$ is uniformly random and independent of b (as long as $\mathcal{A}$ does not query H on exactly $r_b \,\|\, \mathsf{enc}(\mathsf{ctx}_b) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}_b)$). Since r_b has 2^λ possible values and $\mathcal{A}$ makes at most q_H queries, the probability of $\mathcal{A}$ querying the relevant input is at most $q_H/2^\lambda = \mathsf{negl}(\lambda)$. Conditioned on this event not occurring, τ_b is independent of b, so $\mathcal{A}$'s advantage is negligible. □

Remark 9.3 (Overhead). *The randomized variant adds $\lambda/8$ bytes (32 bytes for $\lambda = 256$) to each token and requires one additional random sampling per issuance. The computational cost is unchanged.*

10 Zero-Knowledge Policy Compliance

The constructions in Sections 4 and 9 bind tokens to transaction contexts and (in the randomized case) hide which context was signed. However, a fundamental privacy problem remains: the token itself reveals the claims cls, which may contain sensitive identity attributes, risk scores, or compliance details. In regulated financial systems, a verifier often needs to confirm only that *some valid policy was satisfied*—not which policy, by whom, or with what attributes.

This section addresses this problem by introducing *zero-knowledge compliance privacy*: the token proves that a valid compliance witness exists for the bound transaction context, without revealing the witness, the holder's identity, or the specific policy satisfied.

10.1 Zero-Knowledge Compliance Privacy: Definition

Definition 10.1 (ZK-Compliant Transaction Token Scheme). *A* ZK-compliant policy-bound transaction token scheme *extends Definition 3.1 with:*

- *An NP compliance relation R_{pol} (Definition 2.7).*
- *A NIZK proof system* NIZK *for R_{pol}.*
- $\mathsf{Issue}^{\mathsf{zk}}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls}, w) \to \tau^{\mathsf{zk}}$*: additionally takes a compliance witness w and produces a token containing a zero-knowledge proof.*
- $\mathsf{Verify}^{\mathsf{zk}}(\mathsf{pk}, \tau^{\mathsf{zk}}, \mathsf{ctx}) \to \{0,1\}$*: verifies both the transaction binding and the compliance proof.*

Definition 10.2 (Zero-Knowledge Compliance Privacy (ZK-CP)). *The game* $\mathsf{ZK\text{-}CP}(\mathcal{A}, \lambda)$ *captures the requirement that tokens reveal nothing about the compliance witness beyond the fact of compliance:*

Game $\mathsf{ZK\text{-}CP}(\mathcal{A}, \lambda)$***:***

1. $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$; $(\mathsf{pk}, \mathsf{sk}) \leftarrow \mathsf{KeyGen}(\mathsf{pp})$; $\mathsf{crs} \leftarrow \mathsf{NIZKSetup}(1^\lambda, R_{\mathsf{pol}})$.
2. $(\mathsf{ctx}, \mathsf{pol}, w_0, w_1, \mathsf{st}) \leftarrow \mathcal{A}(\mathsf{pk}, \mathsf{crs})$ *subject to:* $((\mathsf{ctx}, \mathsf{pol}), w_0) \in R_{\mathsf{pol}}$ *and* $((\mathsf{ctx}, \mathsf{pol}), w_1) \in R_{\mathsf{pol}}$.
3. $b \xleftarrow{\$} \{0,1\}$; $\tau_b \leftarrow \mathsf{Issue}^{\mathsf{zk}}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls}, w_b)$.
4. $b' \leftarrow \mathcal{A}(\tau_b, \mathsf{st})$.
5. *Return 1 iff* $b' = b$.

The scheme achieves ZK-CP security if $|\mathbf{Adv}^{\mathsf{ZK\text{-}CP}}(\mathcal{A}, \lambda) - 1/2| = \mathsf{negl}(\lambda)$ *for all PPT* $\mathcal{A}$.

The critical constraint is that *both* w_0 and w_1 must be valid witnesses. This captures the real-world scenario: the adversary (e.g., a curious verifier or network observer) knows that the holder is compliant, but tries to learn *which* compliance path was taken—which identity was used, which KYC provider issued the credential, what risk score was assigned, etc.

10.2 Construction: $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$

Construction $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$

$\mathsf{Setup}^{\mathsf{zk}}(1^\lambda)$: Run $\mathsf{pp} \leftarrow \mathsf{Setup}(1^\lambda)$ and $\mathsf{crs} \leftarrow \mathsf{NIZKSetup}(1^\lambda, R_{\mathsf{pol}})$. Set $\mathsf{pp}^{\mathsf{zk}} := (\mathsf{pp}, \mathsf{crs})$. Return $\mathsf{pp}^{\mathsf{zk}}$.

$\mathsf{KeyGen}^{\mathsf{zk}}(\mathsf{pp}^{\mathsf{zk}})$: Run $(\mathsf{pk}, \mathsf{sk}) \leftarrow \Sigma.\mathsf{SigKeyGen}(1^\lambda)$. Return $(\mathsf{pk}, \mathsf{sk})$.

$\mathsf{Issue}^{\mathsf{zk}}(\mathsf{sk}, \mathsf{ctx}, \mathsf{cls}, w)$:

1. Extract the policy pol from ctx.
2. Compute $r \xleftarrow{\$} \{0,1\}^\lambda$.
3. Compute $h_w := H(\text{“}\texttt{witness}\text{”} \,\|\, r \,\|\, \mathsf{enc}_w(w))$ (witness commitment).
4. Let $\mathsf{cls}' := (\mathsf{cls.public}, h_w)$ (replace private claims with commitment).
5. Compute $m := H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}'))$.
6. Compute $\sigma \leftarrow \Sigma.\mathsf{Sign}(\mathsf{sk}, m)$.
7. Compute $\rho \leftarrow \mathsf{Prove}(\mathsf{crs}, (\mathsf{ctx}, \mathsf{pol}, h_w), (w, r))$ for the relation:

$$R^* := \{((\mathsf{ctx}, \mathsf{pol}, h_w), (w, r)) : ((\mathsf{ctx}, \mathsf{pol}), w) \in R_{\mathsf{pol}} \wedge h_w = H(\text{“}\texttt{witness}\text{”} \,\|\, r \,\|\, \mathsf{enc}_w(w))\}\,.$$

8. Return $\tau^{\mathsf{zk}} := (\sigma, \mathsf{cls.public}, h_w, \rho, r)$.

$\mathsf{Verify}^{\mathsf{zk}}(\mathsf{pk}, \tau^{\mathsf{zk}}, \mathsf{ctx})$: Parse $\tau^{\mathsf{zk}} = (\sigma, \mathsf{cls.public}, h_w, \rho, r)$.

1. Extract the policy pol from ctx.
2. Let $\mathsf{cls}' := (\mathsf{cls.public}, h_w)$.
3. Compute $m := H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}'))$.
4. Check $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m, \sigma) = 1$ (transaction binding check).
5. Check $\mathsf{NIZKVerify}(\mathsf{crs}, (\mathsf{ctx}, \mathsf{pol}, h_w), \rho) = 1$ (compliance check).
6. Return 1 iff both checks pass.

Remark 10.3 (Design Decisions)**.** *Three design choices merit explanation:*

(i) The witness commitment h_w *binds the proof to a specific witness value via the random oracle, preventing proof malleability attacks where an adversary replays a valid proof with a different (invalid) witness.*

(ii) The public claims $\mathsf{cls.public}$ *(e.g., token type, issuer identifier, expiry) remain in cleartext for routing and basic validation. Only the* private claims *(identity attributes, risk scores, policy details) are replaced by* h_w*.*

(iii) The nonce r *in the witness commitment provides hiding: even if the witness space is small (e.g., binary pass/fail), the commitment reveals nothing without* r*.*

Proposition 10.4 (Correctness of Π^{zk})**.** $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ *is correct, assuming* Σ *and* NIZK *are correct.*

Proof. For any valid witness w with $((\mathsf{ctx}, \mathsf{pol}), w) \in R_{\mathsf{pol}}$: the signature σ is computed on $m = H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}(\mathsf{cls}'))$ by $\Sigma.\mathsf{Sign}(\mathsf{sk}, m)$, so $\Sigma.\mathsf{SigVerify}(\mathsf{pk}, m, \sigma) = 1$ by correctness of Σ. The NIZK proof ρ is computed on a valid statement (since w satisfies R_{pol} and h_w is correctly computed), so $\mathsf{NIZKVerify}(\mathsf{crs}, (\mathsf{ctx}, \mathsf{pol}, h_w), \rho) = 1$ by completeness of NIZK. Both checks pass, so $\mathsf{Verify}^{\mathsf{zk}}$ returns 1. □

10.3 Security Analysis

Theorem 10.5 (TB Security of Π^{zk})**.** $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ *is TB-secure. For any PPT adversary* $\mathcal{A}$ *making at most* q_s *issue queries and* q_H *random oracle queries:*

$$\mathbf{Adv}^{\mathsf{TB}}_{\Pi^{\mathsf{zk}}}(\mathcal{A}, \lambda) \le \mathbf{Adv}^{\mathsf{EUF\text{-}CMA}}_{\Sigma}(\mathcal{B}, \lambda) + \mathbf{Adv}^{\mathsf{snd}}_{\mathsf{NIZK}}(\mathcal{C}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}\,,$$

where $\mathbf{Adv}^{\mathsf{snd}}_{\mathsf{NIZK}}(\mathcal{C}, \lambda)$ *is the soundness advantage against the NIZK.*

Proof. The proof extends Theorem 6.1 with one additional case.

The token $\tau^{\mathsf{zk}} = (\sigma, \mathsf{cls.public}, h_w, \rho, r)$ verifies if both the signature check and the NIZK check pass. The signature component (σ, cls') has exactly the same structure as in $\Pi[\Sigma, H]$ with cls' playing the role of cls. Therefore, the reduction $\mathcal{B}$ from Theorem 6.1 applies identically to the signature component: any adversary producing a valid σ^* for an unqueried context yields an EUF-CMA forgery, with the same collision bound.

An adversary could additionally attempt to forge the NIZK component: produce a proof ρ^* for a statement $(\mathsf{ctx}^*, \mathsf{pol}^*, h^*_w)$ where no valid witness exists. This would mean the adversary presents a token that appears compliant but was never backed by a valid compliance witness. By the soundness of NIZK, this succeeds with probability at most $\mathbf{Adv}^{\mathsf{snd}}_{\mathsf{NIZK}}(\mathcal{C}, \lambda)$.

Since the adversary must succeed at *both* forgeries simultaneously (the verification requires both checks to pass), the advantage is bounded by the sum:

$$\mathbf{Adv}^{\mathsf{TB}}_{\Pi^{\mathsf{zk}}}(\mathcal{A}, \lambda) \leq \mathbf{Adv}^{\mathsf{EUF\text{-}CMA}}_{\Sigma}(\mathcal{B}, \lambda) + \mathbf{Adv}^{\mathsf{snd}}_{\mathsf{NIZK}}(\mathcal{C}, \lambda) + \frac{(q_s + q_H)^2}{2^\lambda}\,.$$

The reduction remains tight: $\mathcal{B}$ operates as before, and the NIZK soundness contributes an additive term. □

Theorem 10.6 (Zero-Knowledge Compliance Privacy of Π^{zk})**.** $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ *achieves ZK-CP security in the random oracle model. For any PPT adversary* $\mathcal{A}$*:*

$$\left|\mathbf{Adv}^{\mathsf{ZK\text{-}CP}}_{\Pi^{\mathsf{zk}}}(\mathcal{A}, \lambda) - \frac{1}{2}\right| \leq \mathbf{Adv}^{\mathsf{zk}}_{\mathsf{NIZK}}(\mathcal{A}, \lambda) + \frac{q_H}{2^\lambda}\,,$$

where $\mathbf{Adv}^{\mathsf{zk}}_{\mathsf{NIZK}}$ *is the zero-knowledge advantage against the NIZK.*

Proof. We proceed by a sequence of games.

Game 0 (Real). This is the ZK-CP game: the challenger samples $b \xleftarrow{\$} \{0, 1\}$, computes τ_b using witness w_b, and the adversary outputs b'. The advantage is $|\mathbf{Pr}[b' = b] - 1/2|$.

Game 1 (Replace NIZK proof with simulated proof). Replace $\rho \leftarrow \mathsf{Prove}(\mathsf{crs}, (\mathsf{ctx}, \mathsf{pol}, h_w), (w_b, r))$ with $\rho \leftarrow \mathcal{S}(\mathsf{crs}, (\mathsf{ctx}, \mathsf{pol}, h_w))$, where $\mathcal{S}$ is the NIZK simulator. By the zero-knowledge property of NIZK, the adversary's view differs by at most $\mathbf{Adv}^{\mathsf{zk}}_{\mathsf{NIZK}}(\mathcal{A}, \lambda)$.

Note that in Game 1, the proof ρ no longer depends on w_b at all—it is simulated using only the public statement.

Game 2 (Argue independence of remaining components). After Game 1, the token is $\tau_b = (\sigma_b, \mathsf{cls.public}, h_{w_b}, \rho, r_b)$ where ρ is independent of b. The remaining b-dependent components are:

- $h_{w_b} = H(\text{“}\texttt{witness}\text{”} \,\|\, r_b \,\|\, \mathsf{enc}_w(w_b))$, and
- σ_b, which is a signature on $m_b = H(\mathsf{enc}(\mathsf{ctx}) \,\|\, \mathsf{enc}_{\mathsf{cls}}((\mathsf{cls.public}, h_{w_b})))$.

Since $r_b \xleftarrow{\$} \{0, 1\}^\lambda$ is fresh and H is a random oracle, the input “`witness`” $\|\, r_b \,\|\, \mathsf{enc}_w(w_b)$ is queried to H for the first time with overwhelming probability. Therefore h_{w_b} is uniformly random and independent of b, unless $\mathcal{A}$ queries H on exactly the right input. The probability of this is at most $q_H/2^\lambda$ (since r_b is uniform over 2^λ values and unknown to $\mathcal{A}$).

Conditioned on $\mathcal{A}$ not querying H on the witness commitment input, h_{w_0} and h_{w_1} are identically distributed (both uniform in $\{0, 1\}^\lambda$). Consequently, m_b is independent of b (since it depends on h_{w_b} which is independent of b), and σ_b is independent of b (since it is a deterministic function of sk and m_b for Ed25519, or a randomized function with independent randomness).

Therefore, in Game 2, τ_b is independent of b and $\mathcal{A}$'s advantage is 0.

Combining.

$$\left|\mathbf{Adv}^{\mathsf{ZK\text{-}CP}}_{\Pi^{\mathsf{zk}}}(\mathcal{A},\lambda) - \frac{1}{2}\right| \le \mathbf{Adv}^{\mathsf{zk}}_{\mathsf{NIZK}}(\mathcal{A},\lambda) + \frac{q_H}{2^\lambda}\,.$$

□

Corollary 10.7 (Simultaneous TB + ZK-CP)**.** $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$ *simultaneously achieves TB security (Theorem 10.5) and ZK-CP security (Theorem 10.6). The properties are non-interfering: TB is a property of the signature component, ZK-CP is a property of the proof component, and the witness commitment bridges the two without creating a conflict.*

10.4 Integration with Decentralized Identity (zkDID)

The ZK-CP construction naturally integrates with decentralized identity (DID) systems [29] to provide end-to-end privacy-preserving authorization. We describe the integration architecture and its security properties.

The correlation problem. Standard DID-based authorization reveals the DID itself during each token request. Even with selective disclosure of attributes, the verifier learns *which DID* is requesting access—a persistent correlation vector that enables behavioral profiling across transactions.

zkDID integration. In the zkDID model, the compliance witness w includes a DID credential, and the NIZK proof demonstrates that:

1. The holder possesses a valid DID credential issued by an accredited issuer (membership proof).
2. The credential's attributes satisfy the transaction's policy pol (policy compliance).
3. The credential has not been revoked (non-revocation proof, e.g., via an accumulator [5]).

The verifier learns only: *"a valid, non-revoked credential from an accredited issuer satisfies the policy for this transaction."* The verifier does not learn the DID, the issuer identity (if multiple are accredited), the specific attributes, or any information that could link this transaction to previous ones.

Formal instantiation. The compliance relation for zkDID is:

$$R_{\mathsf{zkDID}} := \left\{ \begin{array}{l} ((\mathsf{ctx}, \mathsf{pol}, h_w), (\mathsf{cred}, r_{\mathsf{acc}}, r)) : \\ \quad \mathsf{cred.issuer} \in \mathsf{AccreditedIssuers} \\ \quad \wedge\ \mathsf{cred.attrs} \models \mathsf{pol} \\ \quad \wedge\ \mathsf{AccVerify}(\mathsf{acc_root}, \mathsf{cred.did}, r_{\mathsf{acc}}) = 1 \\ \quad \wedge\ h_w = H(\text{“}\mathtt{witness}\text{”} \,\|\, r \,\|\, \mathsf{enc}_w(\mathsf{cred}, r_{\mathsf{acc}})) \end{array} \right\}$$

where cred is the DID credential, r_{acc} is the accumulator membership witness, and $\mathsf{acc_root}$ is the current accumulator root (a public parameter).

Trust geometry. The resulting trust architecture cleanly separates three concerns:

- **Issuer accountability:** The credential issuer is identifiable and auditable (their public key is in $\mathsf{AccreditedIssuers}$). Regulators can audit issuers.
- **Holder privacy:** The credential holder is unlinkable across transactions. The verifier cannot correlate requests.
- **Transaction binding:** The token remains cryptographically bound to its specific transaction context. Cross-context reuse is provably impossible.

Concrete cost. Using Groth16 [25] as the NIZK backend, the compliance proof ρ adds 128 bytes (3 group elements on BN254) to the token. Proof generation takes 1–5 seconds depending on circuit complexity (dominated by the credential signature verification inside the circuit). Proof verification takes approximately 3–5 ms, dominated by pairing computations. For payment authorization flows where the issuance can be pre-computed (e.g., during transaction setup), this latency is acceptable.

Table 3: Token size and verification overhead comparison.

Scheme	Token size	Verify time	Privacy
$\Pi[\Sigma, H]$ (base)	264–564 B	$\approx 120\,\mu$s	None
$\Pi^r[\Sigma, H]$ (randomized)	296–596 B	$\approx 120\,\mu$s	Unlinkable
$\Pi^{\mathsf{zk}}[\Sigma, H, \text{Groth16}]$	392–692 B	$\approx$ 3–5 ms	Full ZK-CP

11 Related Work

Bearer tokens and OAuth 2.0. The OAuth 2.0 framework [15] and its bearer token usage specification [16] treat tokens as context-free bearer credentials. Security depends on transport-layer protection (TLS) rather than cryptographic binding to transaction context. The recently ratified OAuth 2.1 [14] consolidates security best practices but does not introduce transaction binding.

Proof-of-possession and DPoP. Demonstrating Proof of Possession (DPoP) [19] binds access tokens to a client-held asymmetric key pair, preventing token export. DPoP addresses *sender constraint*—the token is bound to who holds it—but not *transaction constraint*—the token remains valid across different transactions by the same sender.

Token Binding (RFC 8471). Token Binding [18] binds tokens to TLS connections using key material exported from the TLS handshake. This is *channel binding*: a token is tied to a specific communication channel, not to a specific transaction. Channel binding and transaction binding are orthogonal properties; our model could be composed with channel binding for defense in depth.

Transaction Tokens (RFC 9700). RFC 9700 [21] introduces the concept of Transaction Tokens (Txn-Tokens) scoped to a specific transaction in a microservice call chain. The specification defines a JWT-based format and issuance protocol but provides no formal security model or binding proof. Our work fills this gap by providing the cryptographic definitions and proofs that RFC 9700 lacks.

Macaroons. Birgisson et al. [4] introduced macaroons as authorization credentials supporting contextual caveats via chained HMACs. Macaroons enable flexible attenuation (adding restrictions) but their security analysis focuses on the attenuation property rather than on formal transaction binding. Our TB definition captures a strictly different property: resistance to cross-context reuse, even without attenuation.

GNAP. The Grant Negotiation and Authorization Protocol [20] provides a more flexible successor to OAuth 2.0, supporting fine-grained access delegation. Like OAuth, GNAP treats transaction-scoped enforcement as an application concern rather than a cryptographic one.

Capability-based access control. The capability model [8, 12] treats access rights as unforgeable tokens (capabilities) that can be delegated. Capability systems enforce the principle of least authority but typically do not formalize binding to specific transaction contexts. Our policy-bound tokens can be viewed as capabilities with mandatory transaction binding.

Commitment schemes and binding. Cryptographic commitment schemes [10] provide binding and hiding properties. Our transaction binding notion is related to but distinct from

commitment binding: TB requires that a token binds to its issuance context even against an adversary who controls which contexts are queried, whereas commitment binding prevents changing the committed value. The hash-then-sign structure in $\Pi[\Sigma, H]$ implicitly commits to the context, but our security model captures additional properties (forgery resistance) beyond standard commitment binding.

Provable security for signature-based constructions. Our proof technique follows the standard hash-then-sign paradigm analyzed by Bellare and Rogaway [1] and refined in subsequent work on tight reductions [2, 11]. The tight reduction from TB to EUF-CMA is possible because the hash-then-sign structure allows the reduction to embed the EUF-CMA challenge directly without guessing which query the adversary will attack.

Zero-knowledge proofs and anonymous credentials. The zero-knowledge compliance construction in Section 10 builds on the rich literature of anonymous credential systems. Camenisch and Lysyanskaya [27] introduced practical anonymous credentials with efficient show protocols. Subsequent work on attribute-based credentials [28] formalized privacy-preserving attribute disclosure. Our ZK-CP definition differs in that it captures privacy of the *compliance witness* (which may include identity, attributes, and external proofs) in the specific context of transaction-bound tokens, rather than general credential presentation. The NIZK component can be instantiated by succinct proof systems: Groth16 [25] provides constant-size proofs and fast verification, while PlonK [26] offers a universal trusted setup.

Decentralized identifiers and verifiable credentials. The W3C DID specification [29] defines a framework for self-sovereign identity, and verifiable credentials [30] provide a standard for issuing claims about DID subjects. Our zkDID integration (Section 10.4) extends this framework by proving credential properties in zero knowledge within the transaction binding context, ensuring that DID-based authorization does not create correlation vectors across transactions.

12 Extensions and Open Problems

12.1 Standard-Model Construction

Our proof relies on the random oracle model for the hash function H. A natural open problem is to achieve TB security in the standard model. One approach is to replace H with a collision-resistant hash function (CRHF) and strengthen the signature assumption to strong unforgeability (SUF-CMA). In this setting, the collision term $(q_s + q_H)^2/2^\lambda$ would be replaced by the CRHF advantage, and the proof would proceed similarly. We conjecture:

$\Pi[\Sigma, \mathit{CRHF}]$ *is TB-secure under SUF-CMA and collision resistance, without random oracles.*

A complete proof is left for future work.

12.2 Multi-Issuer Federation

The current model assumes a single honest issuer. In federated systems (e.g., cross-border payment networks with multiple banks), tokens may be issued by different authorities. Extending the model to multi-issuer settings requires:

1. A *federation model* specifying how multiple issuers share or partition the context space.
2. Security definitions accounting for compromised issuers (Byzantine model).
3. Aggregate or multi-signature constructions for jointly-issued tokens.

12.3 Revocation

The current model treats tokens as irrevocable. In practice, tokens must be revocable (e.g., when a transaction is cancelled or a policy is updated). Revocation can be modeled by extending the syntax with a $\mathsf{Revoke}(\mathsf{sk}, \tau) \to \mathsf{RL}$ algorithm and updating the verification to check against a revocation list RL. Efficient revocation (e.g., via accumulators [5]) in the TB setting is an open problem.

12.4 Universal Composability

A UC [6] treatment of transaction-bound tokens would enable formal composition with other protocols (key exchange, payment channels, multi-party computation). Defining the ideal functionality $\mathcal{F}_{\mathrm{TB}}$ and proving that $\Pi[\Sigma, H]$ UC-realizes it is a natural next step.

12.5 Post-Quantum Considerations

Ed25519 is vulnerable to quantum attacks via Shor's algorithm. Post-quantum instantiations of $\Pi[\Sigma, H]$ using lattice-based signatures (e.g., Dilithium/ML-DSA [9]) or hash-based signatures (e.g., SPHINCS+ [23]) are straightforward from a proof perspective—the reduction is generic in Σ—but introduce significant performance trade-offs (larger signatures, slower verification) that merit separate analysis.

13 Practical Deployment Guidance

This section provides guidance for deploying transaction-binding tokens in real-world systems, bridging the formal model to engineering practice.

13.1 Integration with the IETF SPT-Txn Framework

The IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens` [7] specifies three serialization formats: JWT (primary), SD-JWT (selective disclosure), and CWT (CBOR Web Token for constrained environments). Each format maps to $\Pi[\Sigma, H]$ as follows:

- **JWT:** The encoded context $\mathsf{enc}(\mathsf{ctx})$ corresponds to the base64url-encoded JWT header and payload; the claims cls are JWT claims; the signature σ is the JWS signature. The hash H is applied implicitly via the JWS Signing Input construction [17].
- **SD-JWT:** Selective disclosure adds blinded claim digests. The TB property applies to the disclosed subset; unlinkability of undisclosed claims is a separate property addressed by the SD-JWT specification [22].
- **CWT:** The CBOR-encoded context uses deterministic CBOR serialization (RFC 8949) to ensure the injectivity requirement of enc.

13.2 Regulatory Alignment

Transaction binding and zero-knowledge compliance address requirements across multiple regulatory jurisdictions. We organize these by region and framework.

13.2.1 European Union

- **PSD2 / PSD3:** The Payment Services Directive requires Strong Customer Authentication (SCA) with *dynamic linking*—the authentication code must be specific to the transaction amount and payee [31]. TB tokens provide cryptographic enforcement of dynamic linking:

a token issued for a EUR 50,000 transfer to Account B is provably incapable of authorizing a different amount or recipient. The ZK-CP variant additionally enables privacy-preserving SCA where the payment service provider can verify compliance without accessing the payer's full identity attributes.

- **MiCA:** The Markets in Crypto-Assets Regulation requires crypto-asset service providers (CASPs) to maintain transaction-level authorization records and ensure that authorization tokens are not reusable across distinct operations [32]. TB directly enforces non-reusability at the cryptographic layer. For asset-referenced tokens and e-money tokens under MiCA, the ZK-CP construction enables compliance attestation (e.g., reserve adequacy, issuer licensing status) without exposing commercially sensitive reserve composition details.

- **DORA:** The Digital Operational Resilience Act mandates that financial entities maintain verifiable, auditable ICT risk management frameworks with transaction-level audit trails [33]. The deterministic base construction $\Pi[\Sigma, H]$ provides non-repudiable, per-transaction authorization records suitable for DORA audit requirements.

13.2.2 United States

- **SEC — Regulation Crypto Assets and Token Taxonomy:** The SEC's joint interpretation with the CFTC (2026) establishes a token taxonomy distinguishing digital securities, digital commodities, digital collectibles, and stablecoins [34]. For *tokenized securities*, the SEC's position that existing federal securities laws apply [35] means that authorization tokens governing tokenized security transfers must satisfy the same custody, segregation, and audit requirements as traditional securities. TB provides the cryptographic guarantee that an authorization token for a specific securities transfer cannot be repurposed, directly supporting broker-dealer compliance obligations under the Securities Exchange Act.

- **GENIUS Act:** The Guiding and Establishing National Innovation for U.S. Stablecoins Act (signed July 2025) establishes the first federal regulatory framework for payment stablecoins [36]. Permitted payment stablecoin issuers must comply with Bank Secrecy Act (BSA) AML/KYC requirements and maintain 1:1 reserve backing. The ZK-CP construction is directly applicable: issuers and validators can verify that a stablecoin transaction satisfies AML/KYC requirements without exposing the transacting parties' identities to every intermediary in the payment chain. The GENIUS Act's treatment of permitted stablecoin issuers as "financial institutions" under the BSA means that transaction-level compliance records are mandatory—TB tokens provide cryptographically verifiable records.

- **CLARITY Act (pending):** The Digital Asset Market Clarity Act (passed House, pending Senate as of early 2026) aims to delineate SEC and CFTC jurisdiction over digital assets. Once enacted, digital asset brokers, dealers, and exchanges will require clear authorization frameworks for asset transfers. TB tokens provide the per-transaction authorization infrastructure that a market structure bill would require, while the ZK-CP variant addresses the tension between regulatory transparency and user privacy that the CLARITY Act's proponents have highlighted.

- **FinCEN / BSA:** The Bank Secrecy Act requires financial institutions to maintain records of transactions exceeding $10,000 and to file Suspicious Activity Reports (SARs). The zkDID integration (Section 10.4) enables a compliance architecture where: (i) the issuer can verify that BSA thresholds and SAR triggers have been evaluated, (ii) the compliance proof is bound to the specific transaction via TB, and (iii) the transacting party's identity is revealed only to the issuer (not to downstream intermediaries), consistent with the BSA's risk-based approach.

- **OCC / Federal Reserve:** The Office of the Comptroller of the Currency oversees federally qualified nonbank stablecoin issuers under the GENIUS Act. The Federal Reserve is exploring limited-purpose accounts for innovative payment services. TB tokens provide the authorization layer that these new institutional frameworks will require: each payment authorization is cryptographically bound to a specific stablecoin transfer, preventing the replay attacks that have historically plagued bearer-token-based payment systems.

13.2.3 International

- **CIMA (Cayman Islands):** The Cayman Islands Monetary Authority's Virtual Asset Service Provider framework requires transaction monitoring and authorization controls. TB tokens provide per-transaction binding suitable for VASP compliance.
- **VARA (Dubai):** The Virtual Assets Regulatory Authority requires that virtual asset service providers maintain transaction-scoped authorization with full audit trails, directly addressed by the base construction's auditability properties.
- **MAS (Singapore):** The Monetary Authority of Singapore's Payment Services Act and digital asset licensing framework emphasize transaction-level risk management, for which TB provides the cryptographic foundation.

Table 4: Regulatory alignment matrix: which SPT-Txn construction addresses which requirement.

Requirement	$\Pi[\Sigma, H]$	$\Pi^r[\Sigma, H]$	Π^{zk}
Transaction non-reusability	✓	✓	✓
Auditable authorization record	✓		✓*
Dynamic linking (PSD2 SCA)	✓	✓	✓
AML/KYC compliance proof			✓
Holder privacy / unlinkability		✓	✓
BSA threshold verification	✓	✓	✓
Tokenized security custody trail	✓		✓*

*Auditable by authorized parties via selective disclosure of the ZK witness.

13.3 Agentic System Deployment

In AI agent-to-agent communication, transaction binding prevents delegation abuse: an agent authorized for a specific action cannot repurpose the token for a different action. The CWT serialization format is particularly suited to agent-to-agent communication due to its compact binary encoding and suitability for constrained environments. The formal TB guarantee provides the cryptographic assurance that *no computationally bounded agent can exceed its authorized scope*, regardless of the agent's internal architecture or optimization objectives.

14 Conclusion

We have introduced the first formal security model for policy-bound transaction tokens, defining transaction binding as a game-based security notion that simultaneously captures forgery resistance and cross-context reuse resistance. Our construction $\Pi[\Sigma, H]$ achieves TB security with a tight reduction to the EUF-CMA security of the underlying signature scheme in the random oracle model.

We then addressed the complementary privacy challenge by formalizing zero-knowledge compliance privacy (ZK-CP) and constructing $\Pi^{\mathsf{zk}}[\Sigma, H, \mathsf{NIZK}]$, which simultaneously achieves transaction binding and privacy-preserving compliance verification. The integration with decentralized identity systems via zkDID demonstrates that transaction-scoped authorization and holder privacy are achievable in a single construction, with the verifier learning only "compliant" or "non-compliant" while the token remains cryptographically bound to its specific transaction context.

The concrete Ed25519 + Groth16 instantiation provides 126-bit security with practical performance: sub-millisecond verification for the base scheme and 3–5 ms for the ZK-enhanced variant. This makes both constructions practical for deployment in regulated financial infrastructure, cross-border payment networks, and autonomous agent systems.

The formal separation between transaction binding and unlinkability, and the spectrum from the deterministic base construction (auditability) through the randomized variant (unlinkability) to the ZK-enhanced construction (full compliance privacy), highlights the design space available to architects of authorization systems. We have identified several directions for future work, including standard-model constructions, multi-issuer federation, revocation via accumulators, universal composability, and post-quantum instantiations.

This work provides the cryptographic foundation for the SPT-Txn framework and, more broadly, for any system requiring provable transaction-scoped authorization with configurable privacy guarantees.

References

[1] M. Bellare and P. Rogaway. Random oracles are practical: A paradigm for designing efficient protocols. In *Proceedings of the 1st ACM Conference on Computer and Communications Security (CCS)*, pages 62–73, 1993.

[2] M. Bellare, C. Namprempre, and G. Neven. Security proofs for identity-based identification and signature schemes. *Journal of Cryptology*, 22(1):1–61, 2009.

[3] D. J. Bernstein, N. Duif, T. Lange, P. Schwabe, and B.-Y. Yang. High-speed high-security signatures. *Journal of Cryptographic Engineering*, 2(2):77–89, 2012.

[4] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrable, and M. Lentczner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Network and Distributed System Security Symposium (NDSS)*, 2014.

[5] J. Camenisch and A. Lysyanskaya. Dynamic accumulators and application to efficient revocation of anonymous credentials. In *CRYPTO 2002*, volume 2442 of *LNCS*, pages 61–76. Springer, 2002.

[6] R. Canetti. Universally composable security: A new paradigm for cryptographic protocols. In *42nd IEEE Symposium on Foundations of Computer Science (FOCS)*, pages 136–145, 2001.

[7] R. J. Coetzee. Sovereign policy transaction tokens. IETF Internet-Draft `draft-coetzee-oauth-spt-txn-tokens-04`, March 2026.

[8] J. B. Dennis and E. C. Van Horn. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 9(3):143–155, 1966.

[9] L. Ducas, E. Kiltz, T. Lepoint, V. Lyubashevsky, P. Schwabe, G. Seiler, and D. Stehlé. CRYSTALS-Dilithium: A lattice-based digital signature scheme. *IACR Transactions on Cryptographic Hardware and Embedded Systems*, 2018(1):238–268, 2018.

[10] O. Goldreich. *Foundations of Cryptography: Volume 1 – Basic Tools*. Cambridge University Press, 2001.

[11] J. Katz. *Digital Signatures*. Springer, 2010.

[12] M. S. Miller, K.-P. Yee, and J. Shapiro. Capability myths demolished. Technical report, Johns Hopkins University, 2003.

[13] National Institute of Standards and Technology (NIST). FIPS PUB 180-4: Secure Hash Standard (SHS). 2015.

[14] D. Hardt, A. Parecki, and T. Lodderstedt. The OAuth 2.1 Authorization Framework. IETF Internet-Draft, 2024.

[15] D. Hardt. RFC 6749: The OAuth 2.0 Authorization Framework. October 2012.

[16] M. Jones and D. Hardt. RFC 6750: The OAuth 2.0 Authorization Framework: Bearer Token Usage. October 2012.

[17] M. Jones, J. Bradley, and N. Sakimura. RFC 7515: JSON Web Signature (JWS). May 2015.

[18] N. Popov, M. Nyström, and D. Balfanz. RFC 8471: The Token Binding Protocol Version 1.0. October 2018.

[19] D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, and D. Waite. RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPoP). September 2023.

[20] J. Richer and F. Imbault. RFC 9635: Grant Negotiation and Authorization Protocol (GNAP). October 2024.

[21] A. Tulshibagwale, G. Fletcher, and P. Kasselman. RFC 9700: Transaction Tokens. January 2025.

[22] D. Fett, K. Yasuda, and B. Campbell. SD-JWT: Selective Disclosure for JWTs. IETF Internet-Draft, 2024.

[23] D. J. Bernstein, D. Hopwood, A. Hülsing, T. Lange, R. Niederhagen, L. Papachristodoulou, M. Schneider, P. Schwabe, and Z. Wilcox-O'Hearn. SPHINCS: Practical stateless hash-based signatures. In *EUROCRYPT 2015*, pages 368–397, 2015.

[24] A. Fiat and A. Shamir. How to prove yourself: Practical solutions to identification and signature problems. In *CRYPTO 1986*, volume 263 of *LNCS*, pages 186–194. Springer, 1987.

[25] J. Groth. On the size of pairing-based non-interactive arguments. In *EUROCRYPT 2016*, volume 9666 of *LNCS*, pages 305–326. Springer, 2016.

[26] A. Gabizon, Z. J. Williamson, and O. Ciobotaru. PlonK: Permutations over Lagrange-bases for oecumenical noninteractive arguments of knowledge. *IACR ePrint Archive*, 2019/953, 2019.

[27] J. Camenisch and A. Lysyanskaya. An efficient system for non-transferable anonymous credentials with optional anonymity revocation. In *EUROCRYPT 2001*, volume 2045 of *LNCS*, pages 93–118. Springer, 2001.

[28] J. Camenisch, S. Krenn, A. Lehmann, G. L. Mikkelsen, G. Neven, and M. Ø. Pedersen. Formal treatment of privacy-enhancing credential systems. In *SAC 2014*, volume 8781 of *LNCS*, pages 3–24. Springer, 2015.

[29] W3C. Decentralized Identifiers (DIDs) v1.0. W3C Recommendation, July 2022.

[30] W3C. Verifiable Credentials Data Model v2.0. W3C Recommendation, March 2024.

[31] European Parliament and Council. Directive (EU) 2015/2366 on payment services in the internal market (PSD2). November 2015.

[32] European Parliament and Council. Regulation (EU) 2023/1114 on markets in crypto-assets (MiCA). June 2023.

[33] European Parliament and Council. Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA). December 2022.

[34] U.S. Securities and Exchange Commission and Commodity Futures Trading Commission. Joint interpretation clarifying the application of federal securities laws to crypto assets. February 2026.

[35] U.S. Securities and Exchange Commission. Joint staff statement on tokenized securities. Divisions of Corporation Finance, Investment Management, and Trading and Markets, January 2026.

[36] 119th U.S. Congress. S.1582 — Guiding and Establishing National Innovation for U.S. Stablecoins Act of 2025 (GENIUS Act). Signed into law July 18, 2025.